



AI & Partners

Amsterdam - London - Singapore

EU AI Act

NIS2 versus EU AI Act

A Mapping Exercise

August 2025

AI & Partners

Sean Musch, AI & Partners

Michael Borrelli, AI & Partners

Charles Kerrigan, CMS UK

Shreyas Jayasimha, Aarna Law

Eddan Katz, Meta

Avishan Bodjnoud, United Nations



Articles

EU AI Act

NIS2



VS





AI & Partners

Amsterdam - London - Singapore

AI & Partners defends and extends the digital rights of users at risk around the world. By combining direct technical support, comprehensive policy engagement, global advocacy, grassroots professional services, regulatory interventions, and participating in industry groups such as AI Commons, we fight for fundamental rights in the artificial intelligence age.

This report was prepared by Sean Donald John Musch and Michael Charles Borrelli. For more information visit <https://www.ai-and-partners.com/>.

Contact: Michael Charles Borrelli | Director | m.borrelli@ai-and-partners.com.

This report is an AI & Partners publication.





AI & Partners

Amsterdam - London - Singapore

Who Are We

AI That You Can Trust

Why Us?

Stay on the right side of history. At AI & Partners, we believe AI should unlock potential—not cause harm. We’ve seen the fear and fallout when teams lose control of AI, but also the trust and innovation that follow when it’s handled responsibly. That’s why we exist: to help you build AI you can trust and stand behind—for the long run.

80%

of AI systems
are unknown

What Do We Do?

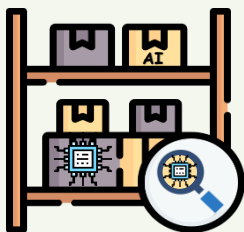
We enable safe AI usage—for your organization and your clients. Unknown AI adoption leads to confusion, risk, and reputational damage. We help you take control with tools to identify, monitor, and govern all AI systems—so you're not reacting to AI, you're leading it.



How Do We Do It?

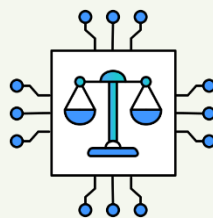
Do you know what AI systems you have? Identify all known and unknown AI systems (algorithms, LLMs, prompts, and models) from all internal and external AI vendors, automated by generating your inventory. Overall, 80% of AI inventory is unknown to our clients.

How do you guarantee ongoing safe AI use? Continuously monitor deployed AI systems for performance drift, anomalies or failures, real-world impacts, and emerging risks (e.g. data poisoning). Any malfunction of an AI system has severe implications for organisations (e.g. inability to assess online misinformation that leads to widespread public mistrust), so monitoring becomes a matter of urgency.



AI Discovery & AI Inventory

Automatically detect all AI systems, including models, algorithms, and prompts, and maintain a live, always-updated register for full visibility and compliance.



Responsible AI

Embed fairness, transparency, and control into every stage of AI use—aligning with the EU AI Act and building ‘Trustworthy-by-Design’.



Model Monitoring

Continuously track your AI models after deployment to detect drift, bias, or failure—so you stay in control and prevent harm before it happens.



Contents

Who Are We	2
Introduction.....	4
Key questions being asked about NIS2.....	5
1. What is NIS2 and why was it created?	6
2. Who does NIS2 apply to?	6
3. What are the key cybersecurity obligations under NIS2?	6
4. What is the role of CSIRTs under NIS2?	6
5. How does NIS2 address supply chain security?	6
6. How is compliance with NIS2 enforced?	7
7. What is the impact of NIS2 on SMEs?.....	7
8. What does the NIS2 require in terms of incident reporting?	7
9. How does NIS2 contribute to EU-wide cybersecurity cooperation?	7
10. What are the transitional measures in NIS2?	7
Understanding NIS2.....	8
Purpose, Scope & Definitions	9
Governance Structure & Authorities	11
Vulnerability Management, Oversight & Implementation.....	13
Mapping NIS2 to the EU AI Act	14
Key questions being asked about NIS2.....	44
Conclusion	46
References	47





Introduction

As the EU regulatory environment rapidly adapts to the expanding role of artificial intelligence, the convergence of the Network and Information Security Directive (NIS2) and the EU Artificial Intelligence Act (AI Act) is becoming essential—particularly for organizations deploying high-risk AI systems in critical sectors. While NIS2 establishes a high common level of cybersecurity resilience across the Union, the AI Act adds targeted obligations for the safe and trustworthy governance of AI technologies, emphasizing lifecycle risk management, oversight, and accountability.

This report offers a practical mapping between NIS2 and the AI Act to help stakeholders align cybersecurity governance with AI-specific compliance. It highlights key areas of intersection—including risk assessment, incident reporting, supply chain security, and competent authority engagement—where coordinated efforts can reduce duplication and strengthen regulatory outcomes.

In making these touchpoints clear, the document supports a harmonized compliance strategy that embeds robust cybersecurity into the design, deployment, and operation of AI systems. In doing so, it helps ensure that high-risk AI applications meet both NIS2's resilience standards and the AI Act's requirements for safety, transparency, and fundamental rights protection.

Whether you are a CISO, AI developer, compliance lead, or legal counsel, this report provides actionable insights for integrating NIS2-aligned cybersecurity measures into your AI governance framework—empowering your organization to manage cyber risks while accelerating secure and responsible AI adoption.

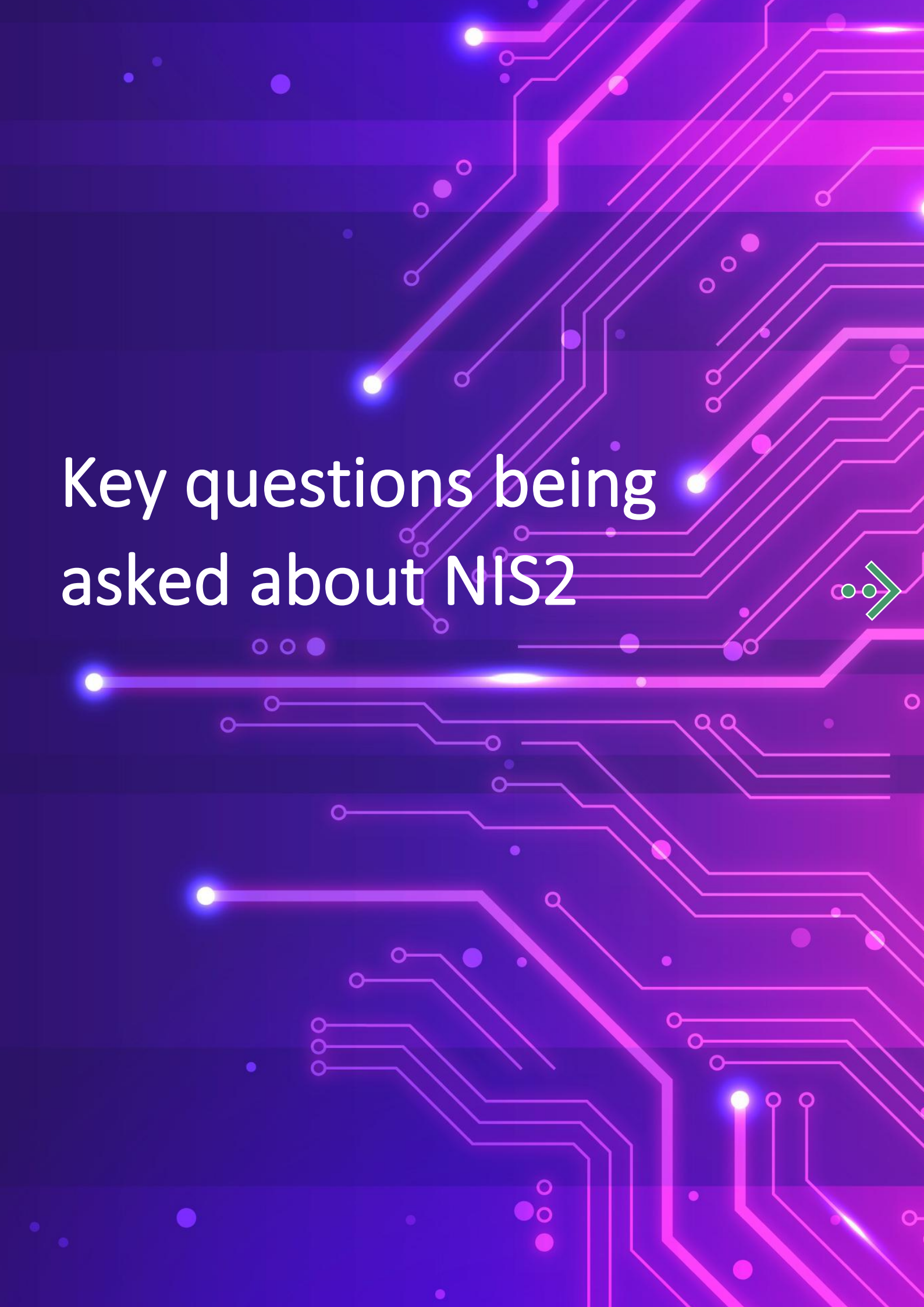
Best regards,

Sean Musch

Founder/CEO

AI & Partners





Key questions being asked about NIS2





1. What is NIS2 and why was it created?

NIS2 (Network and Information Systems Directive 2) is an EU directive designed to improve the cybersecurity resilience of essential and important entities across the European Union. It was created to address the growing risks and challenges associated with cybersecurity threats, the increasing interdependence of digital infrastructures, and the evolving cyber landscape. NIS2 updates the original NIS Directive (NIS1), setting higher security standards, stricter enforcement, and improved cooperation between Member States to protect critical sectors like energy, transport, healthcare, and digital infrastructure from cyberattacks.

2. Who does NIS2 apply to?

NIS2 applies to both public and private sector organizations across critical and digital sectors that are essential for the functioning of society and the economy. This includes sectors such as energy, transport, banking, health, and digital infrastructure. The directive distinguishes between essential and important entities, with essential entities being those in higher-risk sectors. NIS2 also covers managed security services and some digital platforms. Certain national security and defense-related entities are exempted. Member States must designate relevant authorities and ensure compliance by the affected organizations within their jurisdiction.

3. What are the key cybersecurity obligations under NIS2?

NIS2 imposes a range of cybersecurity obligations on entities, including the need for risk management measures, security policies, and incident reporting. Entities must implement robust cybersecurity risk assessments, develop business continuity plans, and ensure appropriate access controls. They are also required to assess risks within their supply chains and address them through secure contractual arrangements. Additionally, entities must report significant cybersecurity incidents to competent authorities and Computer Security Incident Response Teams (CSIRTs) in a timely manner. The objective is to strengthen resilience against cyberattacks and ensure a proactive security posture.

4. What is the role of CSIRTs under NIS2?

Computer Security Incident Response Teams (CSIRTs) play a critical role under NIS2 in responding to cybersecurity incidents, providing expertise, and coordinating across the EU. They are designated by each Member State to assist organizations in managing and responding to security incidents, sharing threat intelligence, and providing guidance on prevention and mitigation. CSIRTs are responsible for receiving incident reports from entities, analyzing the information, and coordinating responses. They are also integral in fostering EU-wide collaboration and information sharing, helping to prevent and respond to large-scale cyber threats across sectors.

5. How does NIS2 address supply chain security?

NIS2 places significant emphasis on supply chain security, requiring organizations to assess cybersecurity risks posed by suppliers and service providers. Entities must implement security measures to mitigate these risks, including secure development practices and ensuring that third-party providers adhere to robust cybersecurity standards. NIS2 mandates that organizations take a proactive approach to identifying vulnerabilities within their supply chains, and that they include cybersecurity clauses in contracts with suppliers. This helps reduce the overall risk of cyber threats and ensures that both upstream and downstream partners maintain secure practices to safeguard the entire supply chain.





6. How is compliance with NIS2 enforced?

NIS2 enforcement is carried out by national authorities designated by Member States. These authorities have the power to audit, inspect, and assess the cybersecurity practices of covered entities. Failure to comply with NIS2 requirements may result in penalties, sanctions, or other enforcement measures. The penalties vary depending on the severity of non-compliance, and they are differentiated for essential and important entities. Additionally, Member States are responsible for ensuring that their national cybersecurity strategies are aligned with NIS2, and they must report to the European Commission on the progress of implementation and compliance efforts.

7. What is the impact of NIS2 on SMEs?

NIS2 recognizes the importance of small and medium-sized enterprises (SMEs) in the digital economy and aims to support their cybersecurity efforts without imposing undue burdens. While SMEs in critical sectors must comply with the Directive, NIS2 includes provisions for tailored guidance, resources, and support to help these businesses implement necessary cybersecurity measures. This includes promoting public-private partnerships, offering cyber hygiene practices, and encouraging the use of open-source tools and AI-driven security solutions. The goal is to empower SMEs to enhance their cybersecurity capabilities and protect themselves against evolving threats.

8. What does the NIS2 require in terms of incident reporting?

Under NIS2, organizations are required to report significant cybersecurity incidents to the competent authorities and CSIRTs within strict time frames. These incidents include cyberattacks, data breaches, and other security threats that may impact the confidentiality, integrity, or availability of services or networks. The reporting must be timely, detailed, and risk-based, allowing authorities to take appropriate action. Entities must also provide updates on the incident as it evolves. This reporting requirement ensures early detection, rapid response, and coordinated efforts across sectors to minimize the impact of cyber incidents on the wider ecosystem.



9. How does NIS2 contribute to EU-wide cybersecurity cooperation?

NIS2 strengthens EU-wide cooperation through mechanisms such as the Cooperation Group and the CSIRTs Network. The Cooperation Group facilitates strategic coordination between Member States, helping align cybersecurity policies, sharing best practices, and ensuring effective implementation of the Directive. The CSIRTs Network allows for the operational exchange of threat intelligence and incident information. In addition, the EU-CyCLONe initiative supports crisis management and coordination during large-scale incidents. By promoting information sharing, collaboration, and coordinated response efforts, NIS2 enhances the EU's collective ability to tackle cross-border cybersecurity threats and improve resilience across the region.

10. What are the transitional measures in NIS2?

Transitional measures in NIS2 allow Member States and affected entities to gradually implement the Directive's requirements. These measures provide a time frame for national governments to transpose NIS2 into local laws, with specific deadlines for compliance. Transitional provisions also offer flexibility for organizations to adjust their systems, policies, and practices in line with the enhanced cybersecurity standards. This includes adapting to new reporting obligations, upgrading security measures, and ensuring coordination with relevant authorities. These transitional measures ensure a smooth shift from the older NIS1 framework to the more robust NIS2 framework without disrupting critical services.

Understanding NIS2





Purpose, Scope & Definitions



What does it mean?

NIS2 is the EU's updated directive aimed at establishing a high and common level of cybersecurity across all Member States. It expands upon NIS1 by addressing new and growing cyber threats and the increasing digital interdependence between sectors and countries. The directive outlines clear goals to improve cyber resilience, boost preparedness, and harmonize cybersecurity practices. It ensures that both national authorities and private entities prioritize risk management, rapid incident response, and cooperation across borders.

Why is it needed?

As digital transformation accelerates, cyber threats have grown more frequent and complex, impacting critical sectors like healthcare, energy, and finance. The previous NIS1 framework was inconsistent across Member States and didn't cover all vital sectors or reflect evolving technologies. NIS2 responds to these challenges by modernizing the EU's cybersecurity legislation, promoting uniform protection levels, and reinforcing coordination across the EU. The directive recognizes cybersecurity as a foundational aspect of EU security, economic stability, and public trust—especially as ransomware, supply chain attacks, and cyber-espionage rise sharply in both scale and sophistication.

How is it implemented?

The European Commission developed NIS2 as a directive that each Member State must transpose into national law. This involves setting up or updating domestic legal frameworks, establishing clear cybersecurity obligations, and designating competent authorities and CSIRTs. Through collaborative bodies like the Cooperation Group and CSIRTs Network, NIS2 facilitates EU-wide alignment and support. Member States are also expected to update their national cybersecurity strategies and involve stakeholders from both the public and private sectors. Timelines for implementation, penalties, and enforcement procedures are specified to ensure consistency and measurable progress.



Cybersecurity Risk Management & Obligations



What does it mean?

Cybersecurity measures under NIS2 refer to the minimum risk-based practices entities must adopt to safeguard networks and information systems. These include conducting regular risk analyses, implementing security policies, ensuring business continuity, access control, data encryption, and regular employee training. Physical and environmental security—like securing server rooms or protection against natural disasters—is also part of this. The measures should be tailored to the organization's risk exposure and criticality. Essentially, these are proactive steps designed to prevent cyber incidents.

Why is it needed?

Cyberattacks often exploit weak or inconsistent cybersecurity practices. Many incidents—such as ransomware infections or data breaches—are preventable with basic hygiene measures like updated systems and trained staff. NIS2 establishes a baseline to ensure all critical and important entities follow structured, risk-based security standards. This protects not only individual organizations but also the broader economy and society, which are interconnected. The lack of uniform cybersecurity in the past left vulnerabilities across sectors. With consistent measures in place, the EU strengthens its overall resilience to both targeted and systemic cyber threats.

How is it implemented?

Each entity must assess its own cyber risks and establish security measures accordingly. These include internal policies, incident response plans, backup and recovery systems, and employee awareness training. National authorities provide technical guidelines and may conduct audits to ensure compliance. Entities must document their security posture and demonstrate that they're actively managing risks. ENISA and the Cooperation Group help define best practices and facilitate cross-border consistency. Compliance is monitored through supervisory authorities, who can issue warnings, recommendations, or penalties depending on the severity of non-compliance.





Governance Structure & Authorities



What does it mean?

NIS2 requires every EU Member State to designate national competent authorities, Computer Security Incident Response Teams (CSIRTs), and a Single Point of Contact (SPOC) for cybersecurity. These bodies oversee, coordinate, and support the implementation of cybersecurity measures across essential and important entities. CSIRTs handle operational aspects like detecting, managing, and mitigating incidents. Competent authorities supervise regulatory compliance and can enforce penalties. SPOCs ensure smooth communication with other EU nations.

Why is it needed?

Without clear responsibilities and specialized teams, cybersecurity efforts can become fragmented, slow, or ineffective. Designating authorities ensures that there's a clear chain of command and accountability when responding to threats. CSIRTs play a crucial role by offering technical expertise and real-time support during incidents. SPOCs help prevent communication breakdowns in cross-border situations. Inconsistent national setups under NIS1 led to gaps and delays in incident response.

How is it implemented?

Member States must legally establish and fund their competent authorities, CSIRTs, and SPOCs. These bodies need to have defined mandates, resources, and independence to perform their roles effectively. CSIRTs must meet EU-defined capability standards—such as 24/7 availability and incident handling frameworks. Competent authorities supervise entities under their jurisdiction, conducting audits, issuing guidelines, and ensuring compliance. SPOCs act as liaisons during EU-level coordination and crisis management efforts. The EU (via ENISA and the Cooperation Group) supports national authorities with best practices, and training to ensure consistent implementation across the Union.



Strategic and Sectoral Policies



What does it mean?

National Cybersecurity Strategies (NCS) are comprehensive plans that each EU Member State must develop and maintain under NIS2. These strategies define national objectives, risk assessments, governance structures, roles of authorities, and mechanisms for public-private coordination. They act as a blueprint for enhancing national cyber resilience and aligning with EU-wide goals. The NCS includes both high-level policy direction and specific action plans for critical sectors, threat intelligence, incident response, and international collaboration.

Why is it needed?

Cyber threats differ across countries and sectors, so tailored national plans are essential. NIS2 ensures that every Member State maintains a structured approach to managing cybersecurity risks, rather than relying on reactive or fragmented measures. Without national strategies, responsibilities can be unclear and coordination weak. The NCS requirement fosters consistency, maturity, and accountability across the EU. It ensures governments are proactive, regularly updating their policies to reflect evolving threats, new technologies, and sector-specific challenges—helping close the gap between national capabilities and EU cybersecurity goals.

How is it implemented?

Member States must draft and publish a National Cybersecurity Strategy that outlines their vision, priorities, and action plans. This includes assigning responsibilities to agencies, setting timelines, budgeting resources, and integrating stakeholder feedback. Strategies are submitted to the European Commission and reviewed for coherence with EU-wide efforts. Updates must occur regularly based on performance evaluations, threat changes, or legal developments. National authorities work with the Cooperation Group and ENISA to align strategies, share best practices, and ensure consistent implementation across Member States.





Vulnerability Management, Oversight & Implementation



What does it mean?

Coordinated Vulnerability Disclosure (CVD) refers to a structured process for identifying, reporting, and addressing cybersecurity vulnerabilities. Under NIS2, Member States must establish national policies and processes for disclosing vulnerabilities in a coordinated manner, ensuring that information is shared between affected parties (e.g., vendors, cybersecurity experts, and regulators). The goal is to resolve vulnerabilities before they are exploited by attackers. In this framework, organizations collaborate with Computer Security Incident Response Teams (CSIRTs) to validate, patch, and disclose vulnerabilities.

Why is it needed?

Without coordination, vulnerabilities can be exploited by attackers before they are publicly addressed, leading to data breaches and systemic risks. CVD ensures a secure and responsible approach to vulnerability disclosure, minimizing the chances of exploitation. By formalizing this process, NIS2 promotes quicker patching, better collaboration, and reduced risks. It provides a clear pathway for organizations to report vulnerabilities without fear of legal repercussions, making it easier for the entire digital ecosystem to improve security. This system helps to prevent cascading effects on critical infrastructure and the economy.

How is it implemented?

Member States are required to establish national policies for Coordinated Vulnerability Disclosure, which include clearly defined reporting channels. CSIRTs play a central role in coordinating the identification, reporting, and resolution of vulnerabilities. They also mediate between the affected parties (e.g., vendors, researchers, affected users) to ensure that proper fixes are applied. National authorities support the process by ensuring legal protection for responsible disclosure and encouraging collaboration across borders. Public awareness campaigns and training help inform organizations about the importance of timely vulnerability reporting and patch management.

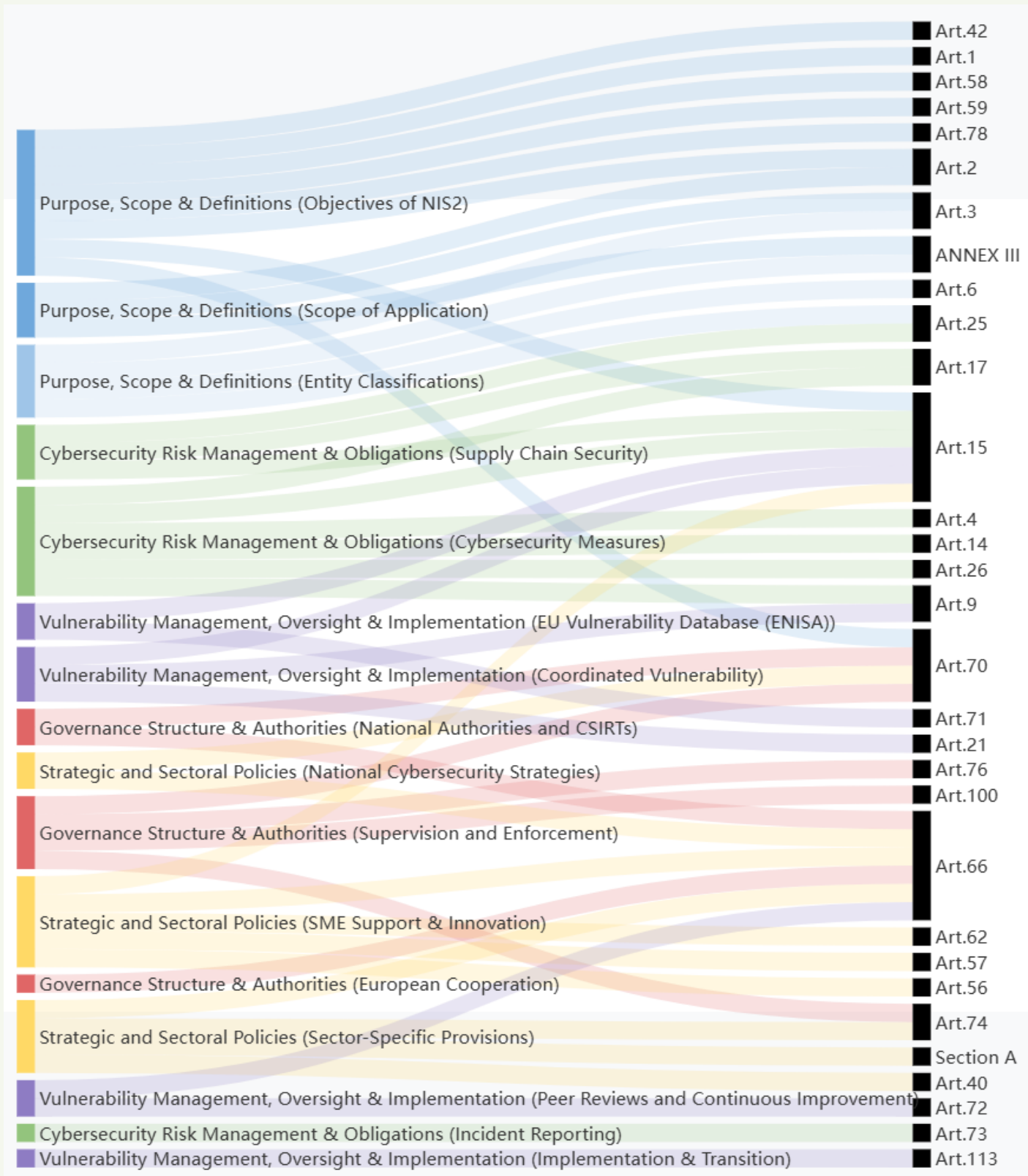
Mapping NIS2 to the EU AI Act





NIS2

EU AI Act





NIS2		EU AI Act		
Section	Description	Provision(s)	Explanation	Action
Purpose, Scope & Definitions	Objectives of NIS2 Establish a high common level of cybersecurity in the EU. Address increasing cyber threats and digital interdependence.	15, 42, 1, 2, 70, 58, 59, 78	Purpose and Scope of the EU AI Act Objective Alignment: The EU AI Act aims to ensure a high level of protection of health, safety, and fundamental rights, which includes cybersecurity as a critical component. Scope: The Act applies to providers and deployers of AI systems within the EU, ensuring that AI systems are safe and secure. Cybersecurity Requirements for High-Risk AI Systems Accuracy, Robustness, and Cybersecurity: High-risk AI systems must be designed to achieve appropriate levels of cybersecurity throughout their lifecycle. This includes resilience against unauthorized alterations and measures to prevent, detect, and respond to cybersecurity threats such as data poisoning	Ensure your AI systems prioritize health, safety, and cybersecurity compliance. Enterprises must review their AI development and deployment strategies to align with the EU AI Act's focus on protecting fundamental rights, including implementing robust cybersecurity measures across all AI operations.





			and adversarial attacks. • Presumption of Conformity: High-risk AI systems certified under a cybersecurity scheme are presumed to comply with the cybersecurity requirements, reinforcing the importance of cybersecurity standards. Governance and Enforcement • Designation of National Competent Authorities: Member States must establish authorities to oversee the implementation of the AI Act, ensuring that cybersecurity measures are enforced. • Confidentiality: Authorities must respect the confidentiality of information, which includes protecting cybersecurity-related data. Support for Innovation and Cybersecurity • AI Regulatory Sandboxes: These sandboxes facilitate the development and testing of AI systems, including	
--	--	--	--	--





			cybersecurity measures, in a controlled environment. • Further Processing of Personal Data: This allows for the processing of personal data in AI sandboxes to develop systems that enhance public safety and cybersecurity.	
	Scope of Application Applies to essential and important entities across critical and digital sectors. Includes public and private sector entities, with national security and defence-related exclusions.	3, 2, ANNEX III	Scope of Application • Scope: The EU AI Act applies to providers and deployers of AI systems within the EU, including those established in third countries if their systems are used in the EU. It covers a wide range of entities, including public authorities, agencies, and private sector entities. • Exclusions: The Act explicitly excludes AI systems used exclusively for military, defense, or national security purposes, regardless of the entity involved. Entities Covered • Definitions: The Act defines various roles such as providers, deployers, importers, and	Define your responsibilities as provider, deployer, or distributor. Clarify internal roles as outlined in Article 3 and align your AI governance based on sector-specific responsibilities, especially if operating in high-risk or critical infrastructure sectors.





			distributors, which encompass both public and private sector entities involved in the AI ecosystem. • Critical Sectors: The Act applies to AI systems used in critical sectors, which are often associated with high-risk AI systems as outlined in Annex III, including sectors like critical infrastructure, healthcare, and public services. High-Risk AI Systems • Classification of High-Risk AI Systems: The Act identifies high-risk AI systems that are subject to stricter requirements, often used in critical sectors that are essential for public safety and security	
	Entity Classifications Essential entities: higher criticality sectors (e.g., energy, transport, health). Important entities: significant but lower risk (e.g., manufacturing, postal services).	ANNEX III, 3, 6, 25	Classification of High-Risk AI Systems • Classification Rules for High-Risk AI Systems: The EU AI Act classifies AI systems as high-risk based on their intended use in critical sectors, which often include essential entities such as energy,	Audit your AI use cases against high-risk criteria. Review the classification rules in Article 6 and Annex III to proactively determine if your AI systems fall under high-risk categories and begin aligning with enhanced requirements.





	Use of size-cap rules and sector relevance for inclusion.		transport, and health. These sectors are typically associated with higher criticality due to their impact on public safety and infrastructure. Sector-Specific Applications • High-Risk AI Systems: An annex lists AI systems used in critical sectors, such as critical infrastructure, healthcare, and public services, which are considered essential due to their significant impact on society. These sectors align with the higher criticality classification. Size and Sector Relevance • Definitions: The Act defines various roles and responsibilities for entities involved in the AI ecosystem, including providers and deployers, which can be both public and private sector entities. The classification of entities as essential or important may depend on their size and the	
--	---	--	---	--





			sector's relevance to public safety and security. Governance and Compliance Responsibilities Along the AI Value Chain: The Act outlines the obligations of providers, deployers, and other parties involved in high-risk AI systems, ensuring that entities in both essential and important sectors comply with the regulatory requirements.	
Cybersecurity Risk Management & Obligations	Cybersecurity Measures Risk analysis and security policies. Business continuity, access control, training. Addressing physical and environmental risks.	15, 9, 17, 4, 14, 26	Risk Management and Cybersecurity Risk Management System: The Act mandates the establishment of a risk management system for high-risk AI systems. It requires continuous assessment and updating to address risks to health, safety, and fundamental rights, aligning with the risk analysis and security policies of NIS2. Accuracy, Robustness, and Cybersecurity: High-risk AI systems must be designed to achieve	Integrate dynamic risk and security controls across your AI lifecycle. Under Articles 9 and 15, enterprises must establish continuous risk assessment, resilience protocols, and oversight to address technical, environmental, and human-factor threats in AI systems.





			appropriate levels of cybersecurity, including resilience against unauthorized alterations and measures to prevent, detect, and respond to cybersecurity threats. Business Continuity and Access Control • Quality Management System: Providers of high-risk AI systems must implement a quality management system that includes procedures for design, development, and quality assurance, supporting business continuity. • Obligations of Deployers: Deployers must ensure that high-risk AI systems are used in accordance with the instructions for use, including maintaining logs and monitoring system operation, which contributes to business continuity and access control. Training and Human Oversight • Human Oversight: High-	
--	--	--	--	--





			risk AI systems must be designed to allow effective human oversight, including training personnel to understand and monitor AI systems, addressing the training aspect of NIS2. • AI Literacy: Providers and deployers are required to ensure a sufficient level of AI literacy among their staff, including training on the operation and use of AI systems. Addressing Physical and Environmental Risks • Accuracy, Robustness, and Cybersecurity: The robustness of high-risk AI systems includes resilience to environmental factors that may affect system performance, addressing physical and environmental risks.	
	Supply Chain Security Assessment of supplier risks. Secure development and contractual measures.	25, 15, 17	Assessment of Supplier Risks • Responsibilities Along the AI Value Chain: The Act outlines the responsibilities of various parties in the AI supply chain, including	Enhance third-party oversight and contractual clarity. Under Article 25, enterprises must conduct due diligence on AI suppliers, enforce compliance clauses, and implement secure development standards





	Specific attention to managed security services.		distributors, importers, and deployers, who are considered providers of high-risk AI systems under certain conditions. This includes ensuring compliance with the obligations of the provider, which inherently involves assessing supplier risks. Secure Development • Accuracy, Robustness, and Cybersecurity: High-risk AI systems must be designed and developed to achieve appropriate levels of cybersecurity, ensuring resilience against unauthorized alterations and cybersecurity threats. This aligns with secure development practices. • Quality Management System: Providers of high-risk AI systems are required to implement a quality management system that includes procedures for design, development, and quality assurance,	to protect the AI value chain.
--	--	--	--	--------------------------------





			contributing to secure development. Contractual Measures • Responsibilities Along the AI Value Chain: The Act emphasizes the need for written agreements between providers and third parties supplying AI systems, tools, services, components, or processes. These agreements specify the necessary information, capabilities, and technical access required to comply with the regulation, reflecting the importance of contractual measures. Managed Security Services • While the EU AI Act does not explicitly mention managed security services, the emphasis on cybersecurity and the responsibilities of providers and deployers to ensure compliance with security requirements indirectly supports the use	
--	--	--	--	--





			of managed security services to maintain the security of high-risk AI systems.	
	Incident Reporting Reporting obligations for significant incidents and threats. Reporting to CSIRTs and competent authorities. Time-sensitive and risk-based response.	73	Reporting Obligations for Significant Incidents • Reporting of Serious Incidents: Providers of high-risk AI systems are required to report any serious incidents to the market surveillance authorities of the Member States where the incident occurred. This aligns with the obligation to report significant incidents. • Time-Sensitive Reporting: The report must be made immediately after establishing a causal link between the AI system and the incident, or within a set timeframe after becoming aware of the incident, depending on its severity. In cases of widespread infringement or serious incidents, the report must be provided within a shorter timeframe. Reporting to Competent Authorities	Establish a structured AI incident response process. Article 73 requires organizations to report major AI incidents within strict timelines—build internal protocols for detection, notification, and resolution of security failures.





			• Cooperation with Authorities: Providers must cooperate with competent authorities during investigations and are prohibited from altering the AI system in a way that may affect subsequent evaluations before informing the authorities. • Notification to National Authorities: Upon receiving a notification related to a serious incident, the relevant market surveillance authority must inform national public authorities or bodies. Risk-Based Response • Risk Assessment and Corrective Action: Following the reporting of a serious incident, providers are required to perform necessary investigations and risk assessments, and take corrective actions to address the incident.	
Governance Structure & Authorities	National Authorities and CSIRTs Member States to designate:	70, 66	Designation of National Competent Authorities • Designation of Authorities and Single Points of Contact: Each	Ensure clear communication channels with AI regulators. Designate internal liaisons to engage with





	Competent authorities CSIRTs Single Points of Contact (SPOCs)		Member State is required to establish or designate at least one notifying authority and one market surveillance authority as national competent authorities for the purposes of the EU AI Act. These authorities must operate independently and impartially to ensure the regulation's application and implementation. • Single Points of Contact: Member States must designate a market surveillance authority to act as the single point of contact for the regulation and notify the Commission of its identity. Responsibilities and Resources • Adequate Resources and Expertise: Member States must ensure that national competent authorities have adequate technical, financial, and human resources, including expertise in AI	national competent authorities as mandated in Article 70, ensuring efficient compliance management and regulatory cooperation.
--	--	--	--	---





			technologies, data protection, and cybersecurity, to effectively fulfill their tasks. Coordination and Cooperation • Tasks of the Board: The European Artificial Intelligence Board facilitates coordination among national competent authorities and supports joint activities of market surveillance authorities, which aligns with the collaborative role of CSIRTs in the NIS2 Directive.	
	European Cooperation Cooperation Group: strategic coordination. CSIRTs Network: operational information sharing. EU-CyCLONe: crisis management and coordination in large-scale incidents.	66	Strategic Coordination • Tasks of the Board: The European Artificial Intelligence Board (the Board) is responsible for advising and assisting the Commission and Member States to facilitate the consistent and effective application of the EU AI Act. This includes contributing to coordination among national competent authorities and supporting joint	Align with EU-wide best practices and cross-border collaboration. Engage with outputs from the European Artificial Intelligence Board (Article 66) to integrate leading guidance, standardization updates, and coordinated AI strategies into your operations.





			activities of market surveillance authorities, aligning with the strategic coordination role of a Cooperation Group. Operational Information Sharing • Tasks of the Board: The Board also collects and shares technical and regulatory expertise and best practices among Member States, supporting operational information sharing similar to the CSIRTs Network. Crisis Management and Coordination • While the EU AI Act does not explicitly mention a mechanism like EU-CyCLONe for crisis management, the Board's role in facilitating cooperation and information-sharing among AI regulatory sandboxes and supporting the development of guidance documents can contribute to managing and coordinating responses to	
--	--	--	---	--





			large-scale incidents.	
	Supervision and Enforcement Differentiated for essential vs. important entities. Powers for audits, inspections, and sanctions.	76, 100, 74, 70	Differentiated Supervision and Enforcement Designation of National Competent Authorities: The EU AI Act requires each Member State to establish or designate national competent authorities, including market surveillance authorities, to ensure the application and implementation of the regulation. These authorities are responsible for supervising compliance with the regulation, which may involve differentiated approaches based on the criticality of the entities involved. Powers for Audits and Inspections Market Surveillance and Control of AI Systems: Market surveillance authorities have the power to conduct audits and inspections to ensure compliance with the regulation. This includes the ability to access documentation,	Get audit-ready with traceable documentation and real-world testing protocols. Articles 74 and 76 grant authorities broad inspection rights—implement secure recordkeeping and real-world testing oversight to stay ahead of enforcement actions.





			data sets, and source code when necessary to assess the conformity of high-risk AI systems. • Supervision of Testing in Real World Conditions: Market surveillance authorities are empowered to supervise testing in real-world conditions, ensuring that such testing complies with the regulation. Sanctions and Penalties • Administrative Fines: The EU AI Act provides for the imposition of administrative fines on Union institutions, bodies, offices, and agencies for non-compliance with the regulation. The fines are determined based on the nature, gravity, and duration of the infringement, among other factors.	
Strategic and Sectoral Policies	National Cybersecurity Strategies Each Member State must adopt a coherent strategy with goals, policies,	70, 66	National Competent Authorities and Coordination • Designation of National Competent Authorities and Single Points of	Integrate AI governance into your national cybersecurity obligations. Under Articles 66 and 70, align your compliance program with broader national





	and coordination frameworks.		Contact: The Act mandates that each Member State establish or designate national competent authorities, including market surveillance authorities, to ensure the application and implementation of the EU AI Act. These authorities are responsible for coordinating efforts and ensuring compliance with the regulation, aligning with the need for a coherent national strategy. Strategic Coordination and Cooperation • Tasks of the Board: The European Artificial Intelligence Board is tasked with facilitating coordination among national competent authorities and supporting joint activities of market surveillance authorities. This strategic coordination is essential for aligning national policies with EU-wide objectives, similar to the	and EU cybersecurity strategies to reinforce consistency and resilience across sectors.
--	------------------------------	--	---	---





			coordination frameworks required by national cybersecurity strategies. Support for National Strategies • Tasks of the Board: The Board also assists national competent authorities and the Commission in developing the organisational and technical expertise required for implementing the regulation, supporting the development of national strategies and policies.	
	Sector-Specific Provisions Integration with other EU legislation (e.g., DORA for finance, Directive 2022/2557 for critical entities). Special rules for sectors like digital infrastructure, aviation, space, health, and telecom.	Section A, 40, 66, 74	Integration with Other EU Legislation • Market Surveillance and Control of AI Systems: This article ensures that market surveillance authorities coordinate with other relevant national authorities or bodies that supervise the application of Union harmonisation legislation. This may include legislation like DORA for finance and the Directive	Coordinate AI regulatory efforts across all applicable EU legislation. Articles 40 and 74 emphasize harmonization with other frameworks like DORA—ensure your AI systems meet both horizontal and sectoral requirements.





			on critical entities. • List of Union Harmonisation Legislation: The EU AI Act references various pieces of Union harmonisation legislation, ensuring that AI systems comply with sector-specific requirements. This includes legislation relevant to sectors such as finance, critical infrastructure, and others. Special Rules for Specific Sectors • Harmonised Standards and Standardisation Deliverables: The EU AI Act promotes the use of harmonised standards to ensure that AI systems meet sector-specific requirements, which can include sectors like digital infrastructure, aviation, space, health, and telecom. • Tasks of the Board: The Board is tasked with facilitating the harmonisation of administrative practices across Member States,	
--	--	--	--	--





			which includes aligning with sector-specific rules and standards.	
	SME Support & Innovation Guidance and resources for SMEs. Promotion of open-source tools, AI, and cyber hygiene practices. Public-private partnerships and cyber education.	62, 57, 15, 66, 56	Guidance and Resources for SMEs Measures for Providers and Deployers, in Particular SMEs, Including Start-ups: Member States are required to provide SMEs, including start-ups, with priority access to AI regulatory sandboxes, organize specific awareness-raising and training activities tailored to their needs, and facilitate their participation in the standardization development process. AI Regulatory Sandboxes: These sandboxes are designed to support innovation by providing a controlled environment for the development, testing, and validation of AI systems, with a focus on SMEs and start-ups. Promotion of Open-Source Tools and AI Codes of Practice: The AI Office	Use regulatory sandboxes and training to accelerate secure AI innovation. Articles 57, 62, and 56 highlight support for SMEs—take advantage of tools, open-source resources, and guidance designed to lower entry barriers while ensuring security.





			encourages the development of codes of practice that may include the promotion of open-source tools and practices, which can be beneficial for SMEs and the broader AI ecosystem. Cyber Hygiene Practices • Accuracy, Robustness, and Cybersecurity: High-risk AI systems must be designed to achieve appropriate levels of cybersecurity, which includes measures to prevent, detect, and respond to cybersecurity threats. This aligns with promoting cyber hygiene practices. Public-Private Partnerships and Cyber Education • Tasks of the Board: The Board supports the development of organizational and technical expertise required for implementing the regulation, which includes promoting AI literacy and public awareness. This can facilitate public-private partnerships and	
--	--	--	---	--





			cyber education initiatives.	
Vulnerability Management, Oversight & Implementation	Coordinated Vulnerability Disclosure National policies for responsible disclosure. Role of CSIRTs as coordinators.	15, 9, 21	Risk Management and Vulnerability Handling Risk Management System: The EU AI Act requires the establishment of a risk management system for high-risk AI systems, which includes the identification and analysis of known and foreseeable risks. This system must be continuously updated, which aligns with the need for coordinated vulnerability disclosure and management. Cybersecurity and Resilience Accuracy, Robustness, and Cybersecurity: High-risk AI systems must be designed to achieve appropriate levels of cybersecurity, including resilience against unauthorized alterations and measures to prevent, detect, and respond to cybersecurity threats. This provision supports the responsible disclosure of vulnerabilities by	Establish a structured approach to AI vulnerability handling. Under Articles 9, 15, and 21, create internal processes for identifying, disclosing, and resolving AI vulnerabilities in coordination with authorities and CSIRTs.





			ensuring systems are robust against potential exploits. Cooperation with Authorities • Cooperation with Competent Authorities: Providers of high-risk AI systems are required to cooperate with competent authorities by providing necessary information and documentation to demonstrate conformity with the regulation. This cooperation can facilitate the role of CSIRTs in coordinating vulnerability disclosures.	
	EU Vulnerability Database (ENISA) Central repository for disclosed vulnerabilities. Supports transparency and mitigation.	71, 15	Central Repository for Disclosed Vulnerabilities • EU Database for High-Risk AI Systems: The EU AI Act establishes an EU database for high-risk AI systems, which includes information about these systems and is maintained by the Commission in collaboration with Member States. This database serves as a central repository for information related to high-risk AI systems,	Engage with the EU AI system database to enhance transparency. Article 71 establishes a central EU database—ensure your high-risk AI systems are registered, up to date, and compliant with disclosure requirements to mitigate risk visibility gaps.





			similar to how a vulnerability database would function for disclosed vulnerabilities. Support for Transparency • Accuracy, Robustness, and Cybersecurity: High-risk AI systems must be designed to achieve appropriate levels of cybersecurity, including resilience against unauthorized alterations and measures to prevent, detect, and respond to cybersecurity threats. This requirement supports transparency by ensuring that vulnerabilities are addressed and disclosed appropriately. Mitigation of Vulnerabilities • Accuracy, Robustness, and Cybersecurity: The article also emphasizes the need for technical solutions to address AI-specific vulnerabilities, including measures to prevent, detect, respond to, resolve, and control attacks.	
--	--	--	---	--





			This aligns with the goal of mitigating vulnerabilities through a central repository.	
	Peer Reviews and Continuous Improvement Self-assessment methodologies for Member States. Best practices, feedback, and EU-wide alignment.	72, 66	Self-Assessment Methodologies • Post-Market Monitoring by Providers: Providers of high-risk AI systems are required to establish a post-market monitoring system that actively collects and analyzes data on the performance of AI systems. This system supports continuous improvement and self-assessment by ensuring that AI systems remain compliant with regulatory requirements throughout their lifecycle. Best Practices and Feedback • Tasks of the Board: The European Artificial Intelligence Board is tasked with collecting and sharing technical and regulatory expertise and best practices among Member States. This facilitates feedback and the	Implement lifecycle AI monitoring to ensure ongoing compliance. Use Article 72 to guide your enterprise toward real-time monitoring, feedback integration, and post-deployment audits for continuous AI improvement.





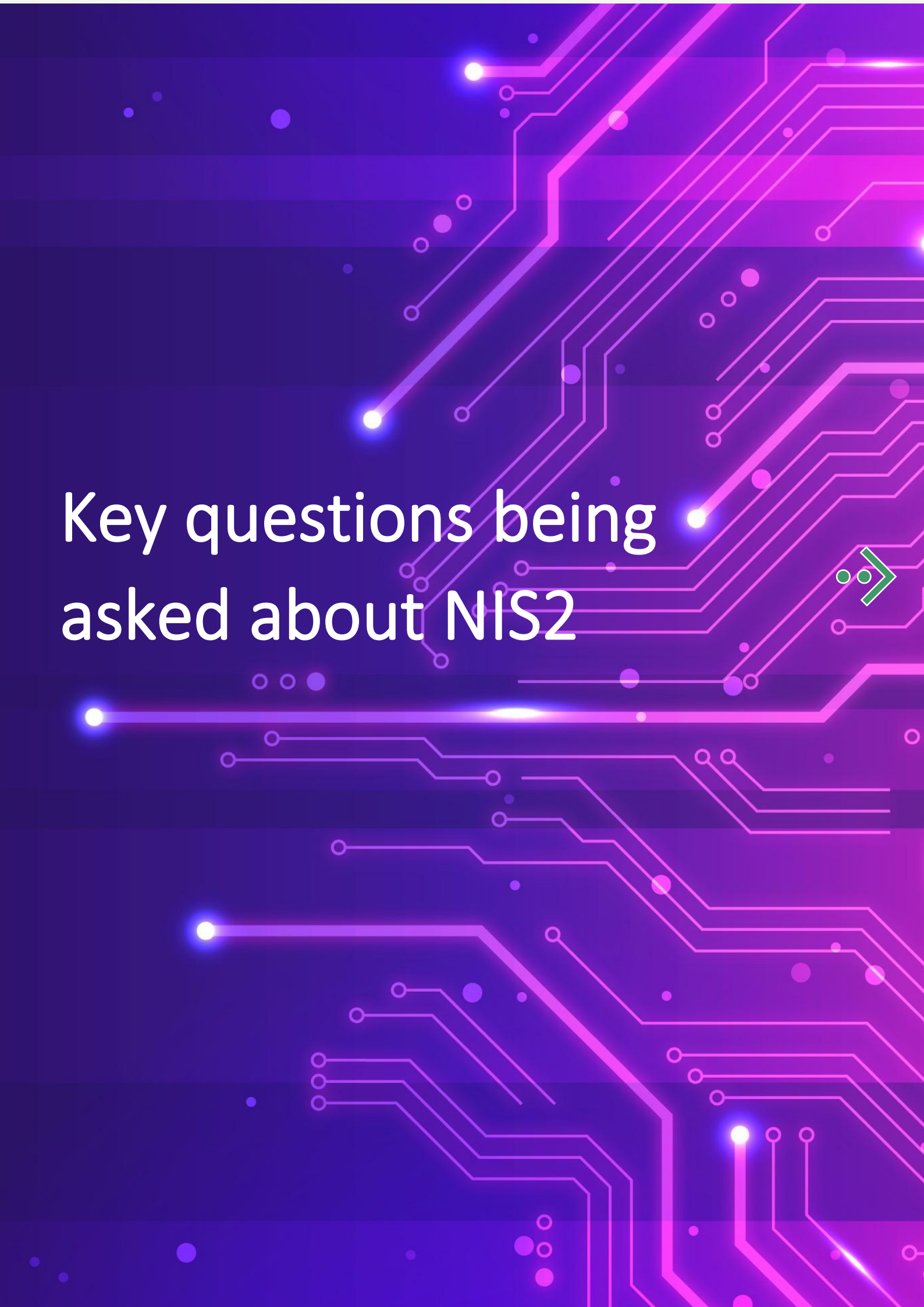
			dissemination of best practices across the EU, contributing to continuous improvement. EU-Wide Alignment • Tasks of the Board: The Board also contributes to the harmonization of administrative practices in Member States, ensuring EU-wide alignment in the implementation and enforcement of the AI Act. This includes supporting the development of common criteria and a shared understanding among market operators and competent authorities.	
	Implementation & Transition Repeal of NIS1 Directive (EU 2016/1148). Transposition deadlines and transitional measures.	113	Repeal of NIS1 Directive • The EU AI Act does not directly address the repeal of the NIS1 Directive (EU 2016/1148) as it primarily focuses on the regulation of AI systems rather than cybersecurity directives. Therefore, there are no specific provisions in the EU AI Act related to the repeal of the NIS1 Directive. Transposition Deadlines	Map out your timeline for staged AI Act compliance by 2025. Article 113 details staggered enforcement dates—develop a roadmap now to ensure readiness for all applicable sections by their respective application deadlines.





			• Entry into Force and Application: This article outlines the application dates for various chapters of the EU AI Act. For instance, some chapters apply from a specific date, while others apply later in the year. These dates serve as the effective deadlines for the implementation of the regulation. Transitional Measures • The EU AI Act does not explicitly mention transitional measures related to the transition from the NIS1 Directive to the NIS2 Directive. However, the staggered application dates provide a form of transitional period for entities to comply with the new requirements.	
--	--	--	--	--





Key questions being asked about NIS2





Apply NIS2 Risk Management to AI System Lifecycle Security

NIS2 requires essential and important entities to implement technical and organizational measures that manage cybersecurity risks. Applying these to high-risk AI systems ensures secure development, deployment, and operation—reinforcing integrity, availability, and confidentiality throughout the AI lifecycle.



Integrate Incident Reporting Protocols into AI System Governance

Under NIS2, organizations must report significant incidents within strict timeframes. Embedding these protocols into AI system oversight guarantees timely detection and coordinated response—enhancing transparency and regulatory alignment under both NIS2 and the EU AI Act.



Strengthen AI Supply Chain Security with NIS2 Supplier Risk Controls

AI systems often rely on complex supply chains. NIS2 emphasizes third-party and supply chain risk management—requiring controls that can be directly mapped onto the AI Act’s requirements for data quality, model robustness, and system integrity in high-risk contexts.



Align Security Policies with Dual NIS2–AI Act Obligations

NIS2 mandates the adoption of security policies and governance frameworks. Harmonizing these with AI Act compliance strategies creates a unified foundation for managing cybersecurity and AI-specific risks, streamlining assurance processes across both regimes.





Conclusion

The intersection of the Network and Information Security Directive (NIS2) and the EU Artificial Intelligence Act marks a pivotal evolution in how high-risk AI systems are secured and governed—ushering in a more unified, accountable, and cyber-resilient regulatory model. As AI becomes deeply embedded in critical infrastructure and essential services, aligning NIS2’s cybersecurity mandates with the AI Act’s lifecycle governance requirements is vital to protecting both digital systems and fundamental rights.

This mapping document has outlined how NIS2 and the AI Act complement one another: NIS2 sets the baseline for risk-based cybersecurity practices across sectors, while the AI Act introduces AI-specific obligations such as human oversight, vulnerability handling, and system robustness. For CISOs, compliance officers, and AI developers, understanding these overlaps is essential to building integrated assurance strategies that meet evolving legal and ethical expectations.

Yet, translating alignment into impact will require strong operational execution. Organizations must adapt their cybersecurity frameworks, incident response protocols, and vendor management practices to meet both directives—particularly in high-risk use cases defined under the AI Act. SMEs and startups may face resource constraints, making early engagement, practical tooling, and cross-functional collaboration even more critical.

Despite these challenges, proactive organizations are already proving that embedding NIS2 and AI Act compliance into AI system design can reduce risk exposure, accelerate regulatory readiness, and build public trust. Together, these frameworks offer a cohesive foundation for securing Europe’s digital future—where AI innovation is not only powerful but also principled and protected.





References

European Parliament and The Council of the European Union, (2022), Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union, amending Regulation (EU) No 910/2014 and Directive (EU) 2018/1972, and repealing Directive (EU) 2016/1148 (NIS 2 Directive) (Text with EEA relevance), accessible at: <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32022L2555> (last accessed 7th May 2025)

European Parliament and The Council of the European Union, (2024), 2024/1689 Regulation (EU) 2024/1689 of the European Parliament and of The Council of 13 June 2024 laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act), accessible at: https://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=OJ:L_202401689 (last accessed 7th May 2025)



Important notice

This document has been prepared by AI & Partners B.V. for the sole purpose of enabling the parties to whom it is addressed to evaluate the capabilities of AI & Partners B.V. to supply the proposed services.

Other than as stated below, this document and its contents are confidential and prepared solely for your information, and may not be reproduced, redistributed or passed on to any other person in whole or in part. If this document contains details of an arrangement that could result in a tax or National Insurance saving, no such conditions of confidentiality apply to the details of that arrangement (for example, for the purpose of discussion with tax authorities). No other party is entitled to rely on this document for any purpose whatsoever and we accept no liability to any other party who is shown or obtains access to this document.

This document is not an offer and is not intended to be contractually binding. Should this proposal be acceptable to you, and following the conclusion of our internal acceptance procedures, we would be pleased to discuss terms and conditions with you prior to our appointment. Images used throughout the document have either been produced in-house or sourced from publicly available sources (see **References** for details).

AI & Partners B.V. is the Dutch headquarters of AI & Partners, a global professional services firm. Please see <https://www.ai-and-partners.com/> to learn more about us.

© 2025 AI & Partners B.V. All rights reserved.

Designed and produced by AI & Partners B.V